

PROOFPRINT

API Contract - Phase 0

Identity & Designer Account Management

Phiên bản	2.0
Ngày cập nhật	20/09/2026
Trạng thái	Đã cập nhật theo nghiệp vụ hiện tại
Base URL	/api/v1

1. Mục tiêu Phase 0

Phase 0 thiết lập danh tính đăng nhập và vòng đời tài khoản Designer. Đây là nền tảng bảo mật trước khi triển khai Workspace, Draft Specification và Customer Review.

- Admin đăng nhập và quản lý duy nhất các tài khoản Designer.
- Designer đăng nhập bằng email và mật khẩu do Admin cấp.
- Access token xác định actor; client không được gửi role hoặc actor_id để tự nhận quyền.
- Tài khoản DISABLED không được đăng nhập và token hiện tại không còn hợp lệ.

Quyết định nghiệp vụ	Customer không có tài khoản, không đăng ký, không đăng nhập và không thuộc bảng users. Designer nhập thông tin Customer khi tạo Workspace ở Phase 1. Vì vậy Phase 0 không có API /customers.
-----------------------------	--

2. Actor và ranh giới quyền

Actor	Được phép trong Phase 0	Không được phép
Admin	Đăng nhập; tạo, xem, cập nhật, khóa/mở và reset mật khẩu Designer.	Không quản lý Customer; không truy cập Workspace; không review hoặc approve.
Designer	Đăng nhập; xem hồ sơ bản thân; đổi mật khẩu của chính mình.	Không tạo hoặc quản lý tài khoản Designer khác.
Customer	Không có chức năng trong Phase 0.	Không có user account, password hoặc bearer token.

3. Danh sách endpoint Phase 0

Method	Endpoint	Auth	Ý nghĩa
POST	/auth/login	Public	Admin/Designer đăng nhập.
GET	/auth/me	Bearer	Lấy Current Actor.
POST	/auth/change-password	Bearer	Đổi mật khẩu của chính actor.
POST	/admin/designers	Admin	Tạo tài khoản Designer.
GET	/admin/designers	Admin	Danh sách Designer.
GET	/admin/designers/{designer_id}	Admin	Chi tiết Designer.
PATCH	/admin/designers/{designer_id}	Admin	Sửa hồ sơ Designer.
PATCH	/admin/designers/{designer_id}/status	Admin	Khóa hoặc mở tài khoản.
POST	/admin/designers/{designer_id}/reset-password	Admin	Đặt mật khẩu tạm thời mới.

4. Authentication API

POST	/api/v1/auth/login	Đăng nhập Admin hoặc Designer
-------------	--------------------	-------------------------------

- Request: email và password; chỉ chấp nhận ADMIN hoặc DESIGNER đang ACTIVE.
- Response 200: access_token, token_type=bearer, expires_in; trả 401 với thông báo chung nếu thất bại.

```
{
  "email": "designer@proofprint.local",
  "password": "Temporary-123!"
}

{
  "access_token": "",
  "token_type": "bearer",
  "expires_in": 1800
}
```

GET	/api/v1/auth/me	Lấy danh tính hiện tại
------------	-----------------	------------------------

- Auth: Authorization: Bearer .
- Response 200: id, email, display_name, system_role; trả 401 nếu token hoặc user không còn hợp lệ.

POST	/api/v1/auth/change-password	Actor tự đổi mật khẩu
-------------	------------------------------	-----------------------

- Request: current_password và new_password.
- Áp dụng cho actor ACTIVE; thành công trả 204 và đặt must_change_password=false.
- Trả 401 nếu mật khẩu hiện tại sai; 422 nếu mật khẩu mới không đạt policy.

5. Admin quản lý tài khoản Designer

POST**/api/v1/admin/designers**

Tạo tài khoản Designer

- Chỉ Admin; system_role luôn do server gán là DESIGNER.
- Request: email, display_name, temporary_password.
- Tạo user ACTIVE và must_change_password=true.
- Response 201: DesignerResponse. Lỗi 409 nếu email đã tồn tại.

```
{
  "email": "designer@example.com",
  "display_name": "Nguyễn Minh",
  "temporary_password": "Temporary-123!"
}
```

GET**/api/v1/admin/designers**

Lấy danh sách Designer

- Chỉ trả tài khoản có system_role=DESIGNER; không trả Admin hoặc legacy Customer.
- Query khuyến nghị: page, page_size, status, q.
- Stable sort: created_at DESC, id ASC.
- Response 200: items và metadata phân trang.

GET**/api/v1/admin/designers/{designer_id}**

Xem chi tiết Designer

- Chỉ Admin; designer_id phải thuộc user có role DESIGNER.
- Response 200: DesignerResponse. Trả 404 nếu không tồn tại hoặc ID thuộc role khác.

PATCH**/api/v1/admin/designers/{designer_id}**

Sửa hồ sơ Designer

- Cho phép sửa display_name; có thể sửa email nếu nghiệp vụ chấp nhận và email mới chưa tồn tại.
- Không nhận system_role, password_hash, created_by hoặc status trong endpoint này.
- Response 200: DesignerResponse. Lỗi 409 nếu email bị trùng.

PATCH**/api/v1/admin/designers/{designer_id}/status**

Khóa hoặc mở tài khoản

- Request status chỉ nhận ACTIVE hoặc DISABLED.
- DISABLED phải chặn lần đăng nhập và lần xác thực token tiếp theo.
- Thao tác lặp lại cùng trạng thái là idempotent.
- Response 200: DesignerResponse.

POST**/api/v1/admin/designers/{designer_id}/reset-password**

Đặt lại mật khẩu Designer

- Request: temporary_password mới; không trả password_hash.
- Sau khi reset: must_change_password=true.
- Response 204. Nên thu hồi token cũ khi hệ thống có token/session version.

6. Data contract

DesignerResponse

```
{
  "id": "uuid",
  "email": "designer@example.com",
  "display_name": "Nguyễn Minh",
  "status": "ACTIVE",
  "must_change_password": true,
  "created_at": "2026-09-20T10:00:00Z"
}
```

Quy tắc dữ liệu

- Email được trim, lowercase để so sánh và unique không phân biệt hoa thường.
- Password chỉ tồn tại ở request; database chỉ lưu Argon2id password_hash.
- Không cho client truyền system_role khi tạo hoặc sửa Designer.
- Không trả password_hash, temporary_password hoặc thông tin bảo mật trong response.
- UserStatus chỉ gồm ACTIVE và DISABLED.

7. Error contract Phase 0

HTTP	Trường hợp
401	Thiếu/sai/hết hạn token; sai email hoặc password; user bị DISABLED.
403	Designer gọi API /admin hoặc actor không đủ quyền.
404	Designer không tồn tại hoặc ID trỏ đến user không có role DESIGNER.
409	Email đã tồn tại hoặc xung đột cập nhật.
422	Request body không hợp lệ hoặc password không đạt policy.

8. Acceptance criteria

- Admin tạo được Designer; Designer đăng nhập bằng mật khẩu tạm thời.
- Designer không gọi được endpoint /admin; Admin không thể tạo một ADMIN khác.
- Email trùng khác hoa/thường bị từ chối; DISABLED chặn login và token tiếp theo.
- Reset password đặt must_change_password=true; đổi mật khẩu thành công đặt lại false.
- Customer không đăng nhập được; response và log không làm lộ password_hash.

Ngoài phạm vi Phase 0

Không triển khai /customers, designer-customer assignment, Workspace, Draft, review link, guest session, Comment, Change Request, Approval hoặc Production Lock trong nhóm API này.

9. Điểm chuyển sang Phase 1

Phase 1 bắt đầu bằng POST /api/v1/workspaces: Designer nhập thông tin Customer; hệ thống tạo Customer record, membership và review link. Customer mở link và nhập username để tạo guest session.